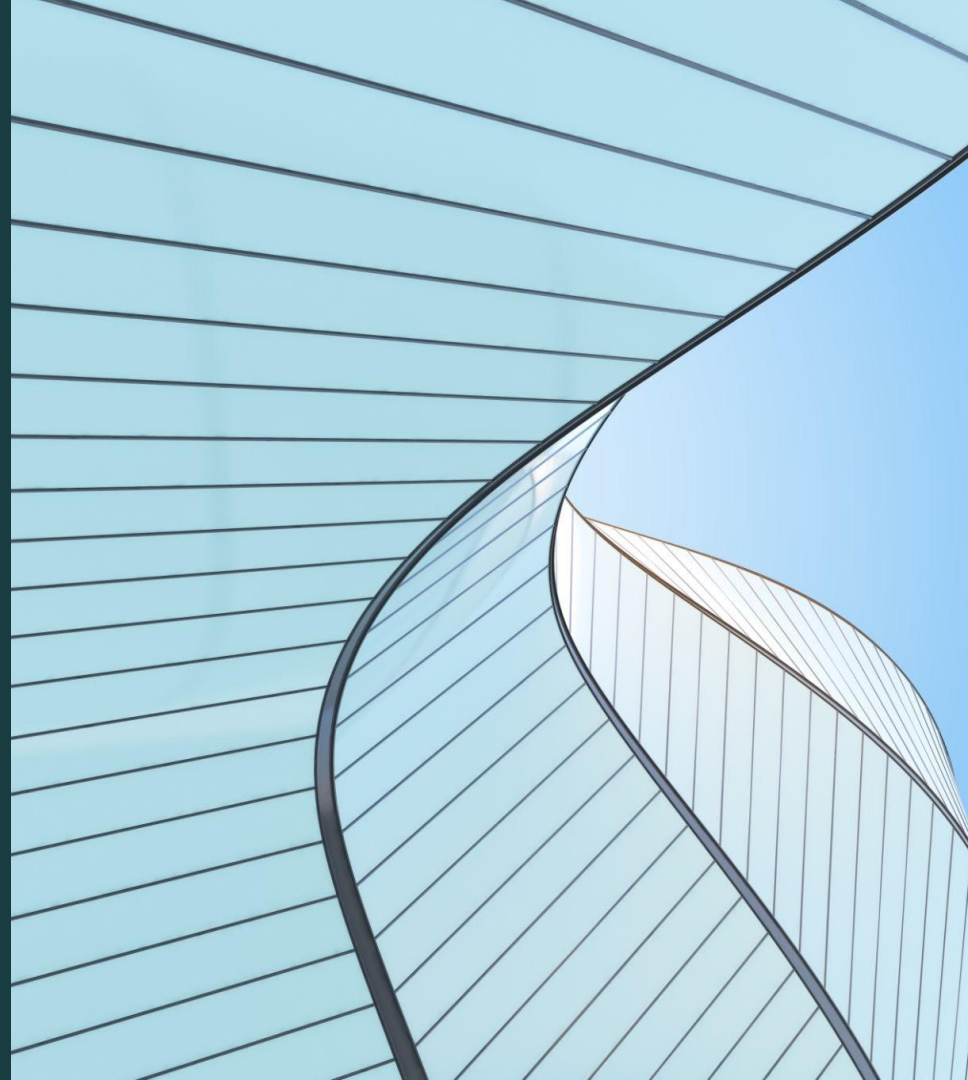


Plan Director de Seguridad

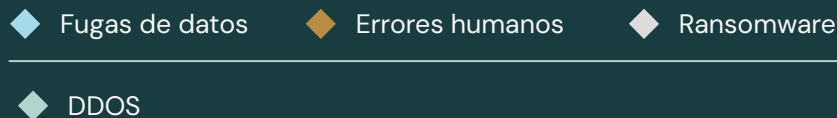
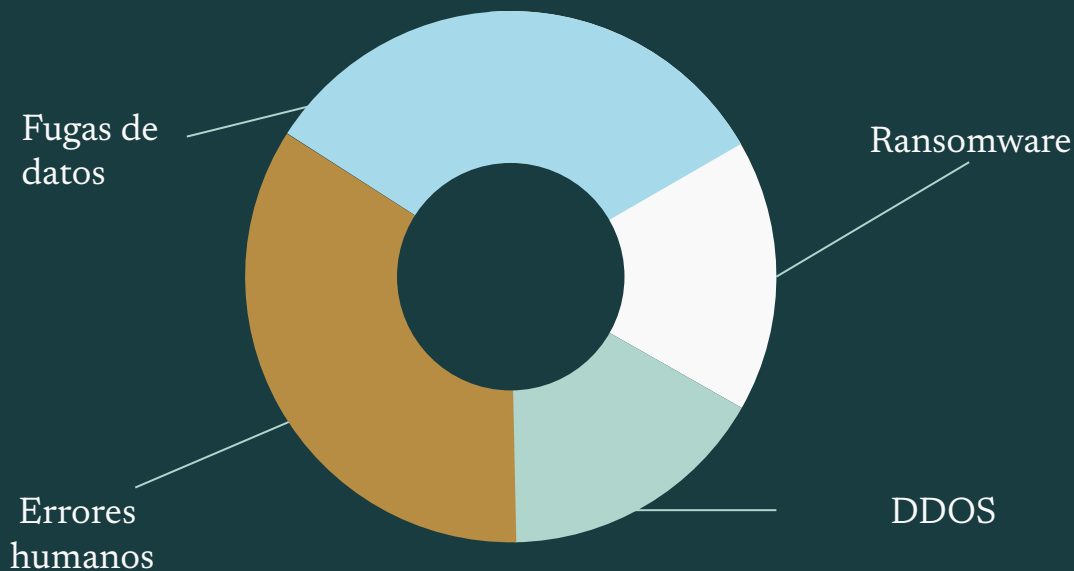
Horizonte: 24 meses

Hoja de ruta clara, basada en riesgos y alineada con vuestros objetivos de negocio. El objetivo es mostraros dónde estamos, qué riesgos existen y qué acciones concretas proponemos para proteger la continuidad del negocio que reduzca el riesgo real y refuerce la confianza de sus clientes.



Por qué estamos aquí

Amenazas actuales del entorno digital



“¿Sentís que la seguridad acompaña al ritmo de digitalización de la empresa?”

Contexto actual

2

- Amenazas crecientes
- Dependencia del canal online
- Responsabilidad legal y reputacional
- Necesidad de enfoque “risk-based”

La empresa ha avanzado en digitalización, automatización, servicios en la nube y presencia online. Sin embargo, no existe un marco formal de seguridad que acompañe ese crecimiento.

Esto genera una brecha entre lo que el negocio necesita y lo que la seguridad actualmente ofrece.

Las amenazas no son escenarios hipotéticos, son el día a día en su sector

¿Qué es este Plan Director?

- Marca la dirección en seguridad
- Prioriza proyectos según riesgo
- Define responsables, plazos y KPIs
- Alinea la seguridad con los objetivos del negocio

El Plan Director de Seguridad no es un documento teórico, es estratégico.

Es su **hoja de ruta** de seguridad para los próximos 24 meses:

qué proteger primero, con qué medidas y quién es responsable.

Lo hemos diseñado con un enfoque práctico y basado en riesgos, partiendo de la **madurez actual** de sus controles, sin sobredimensionar.

Cada euro invertido en este plan persigue un objetivo claro: reducir riesgos críticos, evitar paradas del negocio y cumplir la ley.

Si una acción no aporta valor directo o medible, no entra en el plan.



Situación actual

Hemos partido de su realidad: organización distribuida en dos sedes, fuerte orientación digital, múltiples departamentos que manejan información sensible de clientes y proveedores.

Su ventaja competitiva es la agilidad y la confianza.

Eso implica que cualquier brecha, cualquier parada del canal online, cualquier filtración, impacta directamente en esa confianza.

**Asesoría a
autónomos y
pymes**

**150 empleados
2 sedes**

**Alta dependencia
web**

Tienda online

**Servicios TIC
RRHH
Legal
Comunicación**

¿Sus medidas de seguridad reflejan realmente el valor que hoy tiene lo digital en su negocio?
Este PDS corrige precisamente ese desajuste.

Alcance del plan

- 1 Sedes físicas
- 2 Puestos de trabajo y servidores
- 3 Página web y tienda online
- 4 Servicios cloud
- 5 Procesos internos (ERP, CRM, correo, RRHH...)
- 6 Proveedores TIC
- 7 G. Accesos, incidentes...

Hemos definido un alcance muy claro y eficiente: nos centramos en los activos que si fallan, paran su negocio o exponen datos sensibles. No dispersamos esfuerzos en elementos de bajo impacto

Esto incluye estaciones de trabajo, móviles, servidores, redes, servicios en la nube y especialmente la web y tienda online gestionadas por terceros, donde proponemos reforzar contratos y controles.

Risk-Based

Este enfoque 'risk-based' garantiza que cada acción del PDS tiene impacto directo en continuidad y protección de datos.

EN RESUMEN

6

Hoy: riesgos altos, controles básicos

Mañana: seguridad definida, estable y controlada

Hoy operáis con datos sensibles, múltiples sedes, servicios cloud y una web crítica, pero con controles básicos.

El PDS propone un camino de 24 meses para pasar a un modelo maduro, medible y gobernado.

“¿Qué impacto tendría para vosotros una caída de la web de 48 horas?”

Activos críticos Identificados

Estos activos son el centro del negocio

Datos personales y corporativos

CRM, Correo...

Servidores y servicios cloud

Infraestructura red

Web + tienda online

Personal + proveedores

Identificar qué es crítico nos permite decidir dónde invertir primero.

Riesgos críticos

Los riesgos con mayor impacto real

Caída o indisponibilidad de la web

Fuga de datos personales

Ransomware (servidores/puestos)

Falta de control de accesos y MFA

Backups sin pruebas

Ausencia de política formal

Estos riesgos pueden detener la operativa, generar sanciones o comprometer la reputación.

Modelo de Madurez

Actual a Objetivo en 24 meses



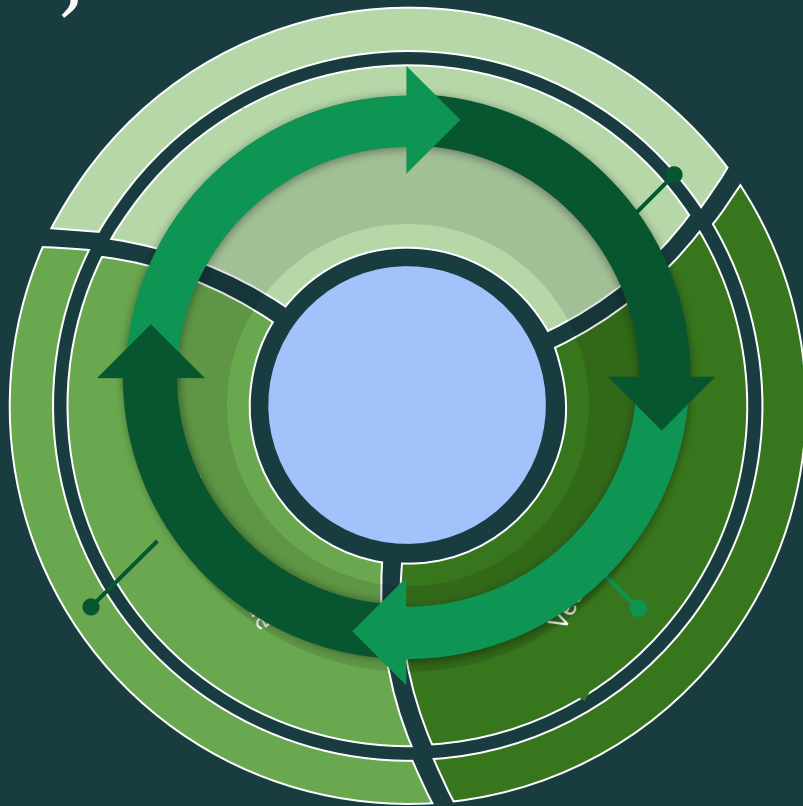
Modelo de mejora continua

PLANIFICAR

- Identificación de activos
- Definición de objetivos
- Valoración de vulnerabilidades

MEDIR

- Revisión cada 6 meses.
- Control de incidentes.
- Evaluación de progreso.



IMPLEMENTAR

- Ejecución de controles de alto impacto.
- Auditorías y cláusulas.

OPTIMIZAR

- Ajustamos el plan
- Correcciones
- Actualizar y metas.

Riesgos prioritarios a tratar

Contexto

Hemos priorizado los riesgos que realmente pueden 'hacer daño'

El PDS que les presentamos está diseñado específicamente para reducir estos riesgos a niveles aceptables, documentados y medibles.

¿Su empresa puede permitirse alguno de estos riesgos?



Objetivos estrategicos

Traducimos el análisis en **objetivos concretos**: proteger la información sensible, asegurar que su canal digital ‘no cae’, cumplir con las obligaciones legales y crear una cultura mínima de seguridad en la organización.

Concepto clave: nivel de riesgo aceptable definido por Dirección (**con nuestra ayuda**). Es decir, ustedes deciden hasta dónde asumir riesgo y el PDS se diseña para mantenernos dentro de ese umbral, con datos y no con sensaciones.

Proteger datos de clientes y proveedores

Garantizar continuidad del negocio

Cumplir normativa RGPD

Establecer cultura de seguridad

Reducir riesgo a nivel aceptable
definido por Dirección

Asegurar disponibilidad

Relación Objetivos-Activos-Riesgos

Cada objetivo resuelve un riesgo real sobre un activo crítico

Objetivo	Activos Críticos	Riesgos Principales	KPI	Prioridad	Plazo
Proteger Datos de Clientes y Proveedores	Datos personales	Fuga o pérdida de datos	15 % —> 60 %	Alta	0-12 meses
Garantizar Continuidad del Negocio	Web y Tienda online, Puestos de trabajo	Fallo técnico, Ataques web, Infección por malware	70 % —> 99 %	Alta	12-24 meses
Cumplir Normativa RGD	Datos personales, Puestos de trabajo, Servidores	Sanciones Económicas	25 % —> 90 %	Alta	12-24 meses
Establecer Cultura de Seguridad	Datos personales, Puestos de Trabajo, Datos personales	Fuga o pérdida de datos, Infección por malware	10 % —> 80 %	Alta	0-12 meses

Esto demuestra que el PDS no es genérico: responde a casos reales de vuestro entorno.

Modelo de madurez objetivo:

Dominio	Estado Actual	Estado Objetivo	Gap
Gobierno y Políticas	Inicial	Definido	2
Hardening tecnológico y copias	Repetible	Gestionado	2
Personas y formación	Inicial	Gestionado	2
Terceros y contratos de seguridad	Inicial	Optimizado	4
Respuesta a incidentes y monitorización	Inicial	Gestionado	3

Líneas estratégicas de actuación

Gobierno & Políticas

Política de seguridad, roles claros y Comité activo.

Hardening tecnológico & copias

Refuerzo técnico, gestión de parches, copias cifradas y probadas.

Personas & formación

Formación específica contra phishing e ingeniería social.

Terceros & contratos de seguridad

Exigir y verificar garantías a proveedores de web, nube, etc.

Respuesta a incidentes & monitorización

Procedimientos claros, tiempos objetivo de recuperación y reporting

Construimos un programa coherente

Proyectos propuestos

16

Aterrizamos en proyectos concretos, cada proyecto viene con alcance, responsables y plazo para que ustedes vean exactamente qué están comprando en términos de seguridad.

Proyecto	Esfuerzo	Prioridad	Responsable
Política de Seguridad y Normativa	Medio	Alta	R. Seguridad
Backup cifrado 3-2-1 + pruebas periódicas	Medio	Alta	Dep. Tic
Gestión centralizada de parches	Medio	Alta	Dep. Tic
Seguridad web/tienda con proveedor y monitor.	Alto	Media	R. Seguridad
Programa anual de formación anti phishing	Bajo	Bajo	RRHH y Seguridad
Plan de respuesta ante Incidentes (IR Plan)	Medio	Alta	R. Seguridad

Matriz de Riesgos y Salvaguardas

Riesgo	Activo	Amenaza	Vulnerabilidad	Salvaguarda propuesta	Nivel	Madurez actual (0-5)	Proyecto PDS asociado	Objetivo estratégico
Cifrado o pérdida de datos	Servidores / BBDD	Ransomware / phishing	Backups no verificados, parches sin control	Backup 3-2-1 cifrado, gestión de parches, EDR, formación anti-phishing	Critico	1 – Inicial	Proyecto de copias de seguridad 3-2-1 y hardening	Continuidad y protección de datos
Caída de web / tienda online	Web corporativa	DDoS / fallo de proveedor	Sin SLA, sin WAF ni monitorización	Auditoría web, WAF, SLA con proveedor, monitorización 24x7	Alto	1 – Inicial	Proyecto de seguridad web y monitorización	Disponibilidad del servicio online
Fuga de información	Datos personales	Pérdida / ingeniería social	Sin cifrado ni control de accesos	Cifrado de datos, MFA, políticas de acceso, formación de usuarios	Alto	1 – Inicial	Proyecto de gestión de identidades y protección de datos	Cumplimiento RGPD y confianza del cliente
Incumplimiento RGPD	Datos personales	Brecha no reportada	Falta de procesos y roles definidos	Plan de respuesta a incidentes, registro de brechas, responsable RGPD	Alto	0 – Inexistente	Proyecto de gobierno y cumplimiento normativo	Cumplimiento legal
Dependencia de terceros	Servicios Web / Cloud	Fallo o brecha de proveedor	Sin cláusulas de seguridad ni auditorías	Revisión contractual, auditorías a proveedores, plan de contingencia	Alto	1 – Inicial	Proyecto de gestión de proveedores críticos	Seguridad en la cadena de suministro
Error humano	Personal	Desconocimiento / mala práctica	Falta de formación y políticas claras	Plan de formación y concienciación, guías de uso seguro, refuerzo de MFA	Medio	1 – Inicial	Programa de concienciación en ciberseguridad	Cultura de seguridad
Fallo en copias de seguridad	Sistemas de backup	Error técnico / ransomware	Copias sin prueba periódica ni cifrado	Backup 3-2-1 cifrado, pruebas de restauración automáticas, supervisión mensual	Critico	1 – Inicial	Proyecto de backup y recuperación ante desastres	Recuperación ante incidentes y continuidad

Prioridad y Roadmap

¿El equipo ha recibido formación en ciberseguridad en el último año?

En esta fase consolidamos la seguridad y reducimos dependencia del factor humano.

Estos proyectos reducen riesgo rápidamente con inversión controlada.

Quick wins críticos

Definir el plan de respuesta a incidentes.

MFA

Gestión de accesos formal

Política de backups + pruebas

Securización de la web + cloud

Inventario de activos

Control de parches,

0-6 meses

Consolidación controles clave

Consolidamos controles, revisamos contratos con terceros y reforzamos la monitorización

6-12 meses

Optimización y mejora continua

Pasamos a optimización, métricas, auditorías internas y mejora continua

12-24 meses

Modelo de Gobierno Propuesto

19

01

Dirección General

02

Responsable
Seguridad / CISO

03

Responsable TIC

04

Responsable Legal /
RGPD

05

Comité de Seguridad

Un plan sin gobierno se queda en papel.

Proponemos una estructura clara:

Dirección como sponsor, un Responsable de Seguridad que coordina, TIC para la parte técnica, Legal para cumplimiento y un Comité de Seguridad que se reúne de forma periódica para tomar decisiones.

El mensaje es sencillo: La seguridad deja de depender de una sola persona y pasa a ser una decisión de negocio.

¿Quién debe estar sentado en ese comité por parte de ustedes?

Beneficios clave

Se reduce la probabilidad y el impacto de incidentes graves, tienen argumentos sólidos ante clientes, auditores y autoridades, y disponen de indicadores claros para saber si la inversión en seguridad está funcionando.

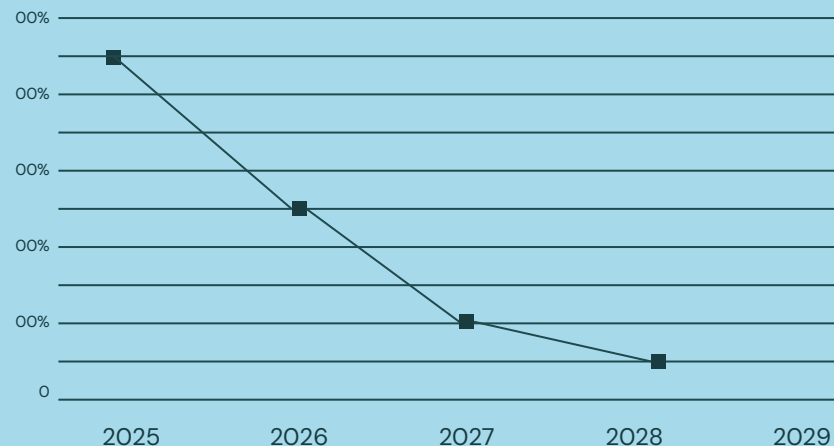
20

Es pasar de 'creo que estamos bien' a 'sé en qué punto estamos y qué estamos cubriendo'. Eso da tranquilidad de gestión y posiciona a su empresa como proveedor fiable en su sector."

¿Qué ganan con este Plan Director de Seguridad?

1. Reducción de riesgos críticos
2. Menos probabilidad de parada total
3. Evidencias de cumplimiento (RGPD, buenas prácticas)
4. Refuerzo reputacional frente a clientes
5. Decisiones basadas en métricas
6. Control y eficacia

Nivel de riesgo

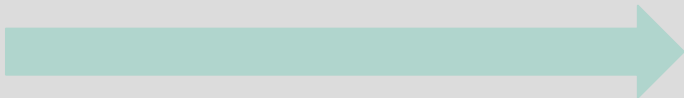


Seguimiento del PDS

El PDS incluye cómo se mide y se gestiona, no sólo qué hacer. Proponemos un cuadro de mando sencillo para Dirección con 4-5 *KPIs clave: actualización de sistemas, fiabilidad de copias, incidentes críticos y tiempos de respuesta.

Además, una revisión semestral del plan permite adaptarlo a cambios de negocio o nuevas amenazas.

Así mantenemos el plan vivo y ustedes mantienen el control estratégico sin entrar al detalle técnico del día a día.



- **Comité de seguridad mensual**
- **Indicadores:**
 - % sistemas parcheados**
 - % copias verificadas**
 - Nº incidentes críticos**
 - Tiempos de respuesta**
- **Revisión semestral del roadmap**

Siguientes pasos

1. Validar alcance y riesgos prioritarios
2. Aprobar PDS y presupuesto asociado
3. Constituir Comité de Seguridad
4. Lanzar quick wins (0-6 meses)

Primero, validar hoy si el alcance y los riesgos prioritarios reflejan su realidad.

Segundo, aprobar el Plan Director de Seguridad con el presupuesto asociado y el compromiso de Dirección.

Tercero, constituir el Comité de Seguridad.

Cuarto, activar de inmediato los quick wins que reducen más riesgo en menos tiempo.

El costo estimado del plan completo son 155.000 € qué puede usted ver en detalle en el documento.

Grupo 1

KiWi Incidentes